

bomblab 报告

姓名：宁祥曦

学号：2024201589

总分	phase_1	phase_2	phase_3	phase_4	phase_5	phase_6	secret_phase
7	1	1	1	1	1	1	1

scoreboard 截图：

2024201589	2	0	0	0	0	3	0	0	0	0	0	0	0	5	7
------------	---	---	---	---	---	---	---	---	---	---	---	---	---	---	---

解题报告

phase_1

But I am so still here surrender the silence...

这题比较简单, 脑内过一遍代码之后就能看清楚%rdx是要读进来一个与地址0x3180处相同的字符串, 否则jmp到exploed_bomb. 0x3180在.rodata段, objdump后就找到了答案. 值得一提的是, 在这题上交了gdb的学费, 这里再次强调给函数打断点一定要记得函数名前加*

phase_2

482112 775614 961314 750365

这题真的是十分复杂, 只能看到跳来跳去的循环, 与sscanf前第二个参数(%rsi)对应地址的字符串为‘%d %d %d’, 能判断出答案是与之格式相同的字符串. 经gpt老师点拨后, 我理解了这里实际上在做一个矩阵乘法, 同时我们能根据 ...(%rdi,%rax,8),%edx... 类似这种语句来判断出矩阵的形状(比如这里每次增加8*rax, rax又是循环中每次+1的寄存器, 说明这里一次跨越了2个4byte, 即2个int; 这是第二个矩阵, 所以说明第二个矩阵是3*2的)最终我们能够判断出是两个形状分别为

$$R^{2 \times 3} \times R^{3 \times 2}$$

的矩阵相乘, 找到地址对应的那12个整数后, 我们按照矩阵乘法将其乘起来, 就得到答案所要的4个整数.

phase_3

```
/* I guess this is too easy so far.  Some more complex code will
   * confuse people. */
5 -421
```

这是Dr. Evil的原话, 你敢和它对视超过两秒吗?()

回到正题, 这题的难度真是一下子就降下来了. 依旧老套路, 先找到rsi对应格式字符串‘%d %d’, 而这题相对简单的逻辑让我能够直接脑内跑上一遍.

sscanf之后的四句:

156d:	83 f8 01	cmp	\$0x1,%eax
1570:	7e 07	jle	1579 <phase_3+0x35>
1572:	83 7c 24 04 00	cmpl	\$0x0,0x4(%rsp)
1577:	78 05	js	157e <phase_3+0x3a>

立刻推知rax>1(其实就是=2, 即读进来两个数), *rsp=0

打好explode前的断点, 随后我们不断si, 在所有判断处print/x, 立刻获得要传入的两个整数的边界条件; 传入边界条件试了试之后直接过了, 因此省了不少麻烦.

phase_4

31 AB

这题稍稍有些新颖, 格式字符串是‘%d %2s’, 不过过程仍旧很简单, 打好断点后看准寄存器与对应参数不断si, 在跳跃前print出对应边界条件, 发挥gdb神力就能够轻松解决. 实际上真去过逻辑还是比较复杂的.

phase_5

-6 38

这题又上了点强度, 主要是这里我真没搞懂第一个%d参数的准确值是什么(跳来跳去的没找到规律), 根据一个cmp0后的js(此处必须跳以此跳过explode_bomb)和and+je(此处跳了直接炸), 只能判断出第一个参数<0且低八位不为0xFF(即!=-1). 所幸这题范围较小, 直接在-2到-14之间暴力破解即可, 最后得到第一个答案是-6.

随后的第二个答案可以在判断跳跃时print出来, 依旧gdb神力解决.

phase_6

6 5 1 2 3 4

这题惨绝人寰, 跟了若干小时未果, 只能判断出答案是6个int以及均小于6; 随后找了个b站视频看, 学习后知道了答案是1, 2, 3, 4, 5, 6的一个排列, 于是直接打断点开试.

虽然可能性非常多, 好在这题每次断点能够提供的信息也很多, 每次断点至少能够看到第二个答案对应的值, 不断更换参数(最多只需要试5次), 依次记下来后按照对应值的降序输入排列, 即为答案.

secret phase

33022

这题非常重量级, 即使不考虑func7的一大坨, 为了搞清楚怎么进入secret_phase也着实花了我不少功夫. 在phase_defused中能够看到secret_phase, 一步步跟下来能得到进入其中的逻辑:

1. 必须是phase_6解决后
2. (正常的phase_6答案进不去)答案中必须有6个空格
3. 最后一个空格分割出的字符串要与地址在0x3621的字符串一致. (找到后发现其实就是readme中的 secret word: arcaea)

诚如题中所言: finding it and solving it are quite different..., 想要解决这个secret_phase, 我们需要过一遍func_7

进入func_7之前, 在secret_phase函数中分析, 我们能判断出: 输入的一行字符串作为第一个参数传进func7, 要求返回值不能为0

func7前半段一直在将很多数字塞到栈中,

反馈/收获/感悟/总结

花费时间: 10h左右?

感觉非常困难, 尤其是柴老师尚未完整讲完汇编, 对汇编语法十分陌生.

现在回头再看, 很多循环当时都没意识到, 更不要提惨绝人寰的矩阵乘法了; 格式字符串的寻找也命中了我的知识盲区, 好在网上的资料足够丰富()

不过对于汇编的能力提升, 个人感觉效果真的是非常明显, 很锻炼能力. 写汇编虽然还有些生疏, 但是读汇编的速度大大提升了.

参考的重要资料

[https://www.bilibili.com/video/BV1vu411o7QP?
spm_id_from=333.788.videopod.episodes&vd_source=9139548dcd935d2d98854e91ff25b0aa&p=12](https://www.bilibili.com/video/BV1vu411o7QP?spm_id_from=333.788.videopod.episodes&vd_source=9139548dcd935d2d98854e91ff25b0aa&p=12)